

Project - Protocol Hardening

Aleksander Klap

08.06.2026

1 Protocol Hardening

The redesign (Chapter 7) controls where each protocol may flow. This chapter defines how each protocol is secured on the device and conduit level.

1.1 Profinet

Profinet has no authentication or encryption features, so it cannot be hardened at the protocol level. Instead it is secured by isolation.

- Layer 2 only - Profinet stays inside each OT Production station (VLAN 101 - 106). It is never routed, and never crosses through firewall. Even if routing would be executed (through the attack) router would drop the communication.
- No inter-station Profinet communication - Each PLC talks Profinet (with I/O, HMI) only within own VLAN.
- DCP Set disabled - disable DCP Set through TIA Portal for devices that support this feature. This prevents rename/reconfigure attacks through DCP.

1.2 OPC UA

OPC UA is the only routed OT data protocol. Hardening is specified in SR-03. (*see Security Requirements 6.1 TODO*)

- Security mode Sign&Encrypt - Security policy Basic256Sha256. Mode 'none' is disabled on all PLC and Festo Controllers servers.
- Certificate authentication - Clients (OPC UA proxy, Cobot/MLvisionPC) authenticate with application certificates. Anonymous and username/password sessions are disabled.
- Scoped access - The Cobot/MLvisionPC can reach only PLC2 on Station 2, and no other PLC's.

1.3 MQTT

MQTT is used by the Festo CXV device for telemetry. It's hardening is specified in SR-04 (*see Security Requirements 6.1 TODO*)

- MQTT broker in IDMZ - The MQTT CXV device publishes only to a dedicated MQTT broker placed in IDMZ. IT nodes can only subscribe to the broker. No direct OT-IT MQTT path exists.
- TLS 1.2+ - TLS encryption enforced on all MQTT connections.
- Client certificates - MQTT CXV device must authenticate with certificate for publish connection to the broker. No anonymous connections allowed.
- Topic ACL's - The MQTT CXV device may publish only to it's own topics. IT nodes (MES) cannot publish to the OT topics.

1.4 HTTP/Web Interfaces

Some OT devices need to expose plaintext HTTP web interfaces. Hardening is specified in SR-05 (*see Security Requirements 6.1 TODO*)

- Disabled by default - All HTTP servers are disabled unless strictly needed for operational functionality.
- Reverse proxy - Where web access is needed (e.g. MES reading the PLC alarm table), the MES connects to the Nginx reverse proxy in the IDMZ over HTTPS/TLS 1.2+. Nginx terminates the connection, fetches the OT-side resource, and returns it. Plaintext HTTP stays inside the OT zone.
- Access restriction - Nginx authenticates requests, logs them and blocks any OT server that should not be reached from IT zone. Firewall rules restrict web access to the Nginx TCP/IP port only.

1.5 S7comm+ Engineering Access

S7comm+ connection is used only for programming PLC's and HMI's. Hardening is specified in SR-06 and SR-07 TODO link to SR's

- Single source - S7comm+/TCP102 to any PLC or HMI is allowed only from the dedicated Engineering Workstation in VLAN40.
- Conduit control - Engineering Workstation S7comm+ connection initialization passes through the firewall, enforcing restriction of Engineering Station to PLC's and HMI's only.
- User Authentication - PLC's and HMI's access requires individual login/password authentication with role separation (implemented in TIA portal).